

Vendor Security Due Diligence Questionnaire

Based on Shared Assessments SIG Lite

Vendor: Deloitte

Service: AI Governance Consulting

1. Information Security Governance

Question	Response
Do you maintain a documented Information Security Program?	Yes
Do you maintain an ISO/IEC 27001 certified ISMS?	Yes
Can a current ISO/IEC 27001 certificate be provided upon request?	Yes
Is information security reviewed by executive leadership?	Yes

2. Identity & Access Management

Question	Response
Is MFA required for employee access to corporate systems?	Yes
Are privileged accounts reviewed regularly?	Yes
Is access removed promptly upon employee termination?	Yes

3. Data Protection

Question	Response
Is confidential client information encrypted in transit?	Yes

Is confidential client information encrypted at rest?	Yes
Do you maintain documented data retention and disposal procedures?	Yes
Will PUC data be stored within Canada?	No – Data residency will be determined based on the engagement and client requirements.

4. Incident Response

Question	Response
Do you maintain a documented Incident Response Plan?	Yes
Are incident response exercises performed periodically?	Yes
Will Deloitte notify PUC of a security incident affecting engagement data?	Yes

5. Business Continuity

Question	Response
Do you maintain Business Continuity and Disaster Recovery plans?	Yes
Are recovery plans tested periodically?	Yes

6. Compliance & Assurance

Question	Response
Has Deloitte completed a SOC 2 Type II audit?	Yes
Can an executive summary of the SOC 2 report be provided under NDA?	Yes
Are independent penetration tests conducted periodically?	Yes

7. Third-Party Management

Question	Response
Does Deloitte maintain a third-party risk management program?	Yes
Does Deloitte perform security due diligence and ongoing monitoring of critical third-party service providers and subcontractors?	Yes . Risk-based due diligence is performed before onboarding critical third parties and reassessments throughout the vendor lifecycle are conducted.
Are subcontractors subject to security requirements?	Yes
Will subcontractors be used for this engagement?	No subcontractors are expected to be used.

8. AI Governance

Question	Response
Does Deloitte maintain internal policies governing the responsible use of AI?	Yes
Are employees provided guidance on the appropriate use of AI technologies?	Yes
Will customer information be used to train AI models?	No

Supporting Documentation Available

- ☒ ISO/IEC 27001 Certificate
- ☒ SOC 2 Type II Executive Summary (under NDA)
- ☒ Information Security Policy Overview
- ☒ Incident Response Summary
- ☒ Business Continuity Overview